Cours 2

Introduction à la Sécurité Informatique (Partie 2)

Prof. Omar Rafik Merad Boudia

rafik.merad@univ-oran1.dz

3ème année Licence (LMD) – Semestre 2

Université d'Oran 1, Ahmed Ben Bella

Année Universitaire 2025–2026

25 janvier 2026

Sommaire de ce cours

1. Les Enjeux de la Cybersécurité
2. Une Politique de Sécurité Informatique
3. L'Audit de Sécurité
4. Les Antivirus : Définition et Mécanismes
5. Les Pare-Feu (Firewalls)
6. Carrière et Certifications
7. Conclusion
8. Bibliographie

Les Enjeux de la Cybersécurité

La sécurité informatique dépasse le cadre technique pour toucher au cœur de la société.

Menaces sur l'individu :

- **Vie privée :** Vol et exploitation de données personnelles.
- **Exclusion numérique :** Vulnérabilité des populations non sensibilisées.
- **Confiance :** Méfiance croissante envers les services en ligne.

Menaces sur la société :

- **Opinion publique :** Manipulation via la désinformation et les fake news.
- **Services publics :** Cyberattaques contre la santé, l'éducation et l'administration.
- **Stabilité :** Tentatives de déstabilisation sociale.

Les attaques ont des conséquences directes et indirectes sur le tissu économique.

- **Pertes directes :** Vols financiers, rançongiciels (ransomware).
- **Propriété intellectuelle :** Espionnage industriel et perte d'avantages concurrentiels.
- **Opérationnel :** Arrêt de production et perturbation des chaînes d'approvisionnement.

Impacts à long terme

Au-delà des pertes immédiates, les entreprises subissent une dégradation de leur réputation, une perte de confiance client et une baisse de leur valeur sur les marchés financiers.

Le défi législatif

La technologie évolue plus vite que la loi. Le cadre est souvent en retard sur les nouvelles menaces (IA, cryptomonnaies).

Focus : La situation en Algérie

- **Cadre actuel :** Loi n° 09-04 (août 2009) sur la cybercriminalité.
- **Défis :** La protection des données personnelles reste un chantier important.
- **Évolution :** Des projets de loi sont en cours pour renforcer la sécurité et le commerce électronique.

Note : La cybercriminalité ne connaît pas de frontières, et l'Algérie, comme d'autres nations, doit constamment adapter son cadre juridique pour faire face aux menaces émergentes.

Source

L'évolution du nombre d'affaires traitées par la DGSN témoigne de l'ampleur du phénomène.

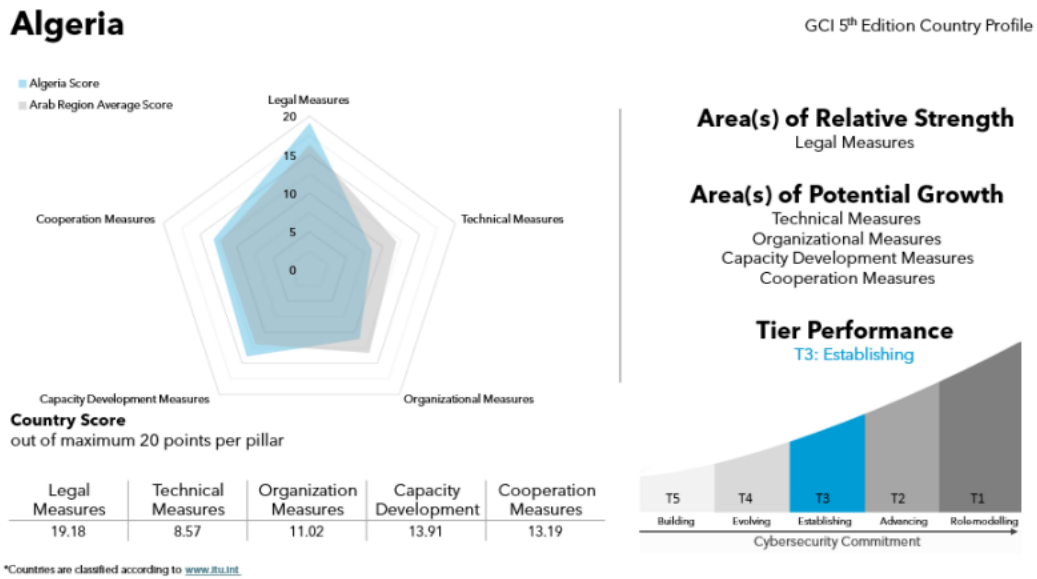
Année	**Nombre d'affaires**
2014	246
2015	567
2016	1 055
2017	2 130
2019	4 210
2020	**5 163**

Remarque

Entre 2014 et 2020, le nombre d'affaires a été multiplié par plus de 20. Cela inclut l'intimidation, le chantage et l'usurpation d'identité.

Source 1, **Source 2**

Cybersécurité en Algérie – Global Cybersecurity Index (2024)



Lecture du graphique

- Évaluation basée sur **5 piliers**
- Score maximal : **20 par pilier**
- Comparaison avec la **moyenne régionale**

Résultats clés

- **Point fort :** mesures juridiques (19.18/20)
- **À améliorer :** mesures techniques (8.57/20)
- **Niveau global :** T3 – Establishing

Source

	Pays*	Pourcentage des utilisateurs attaqués**
1	Iran	47,35%
2	Bangladesh	36,25%
3	Indonésie	32,97%
4	Chine	32,47%
5	Népal	29,90%
6	Inde	29,09%
7	Algérie	28,64%
8	Philippines	27,98%
9	Nigeria	27,81%
10	Ghana	25,85%

Le mobile est devenu une plateforme critique, concentrant désormais plus de trafic web que les ordinateurs classiques.

Classement Mondial (Malwares Mobiles)

L'Algérie se classe parmi les pays les plus visés par les malwares sur mobile.

Top 3 des pays attaqués :

1. Iran (47,35%)
2. Bangladesh (36,25%)
3. Indonésie (32,97%)

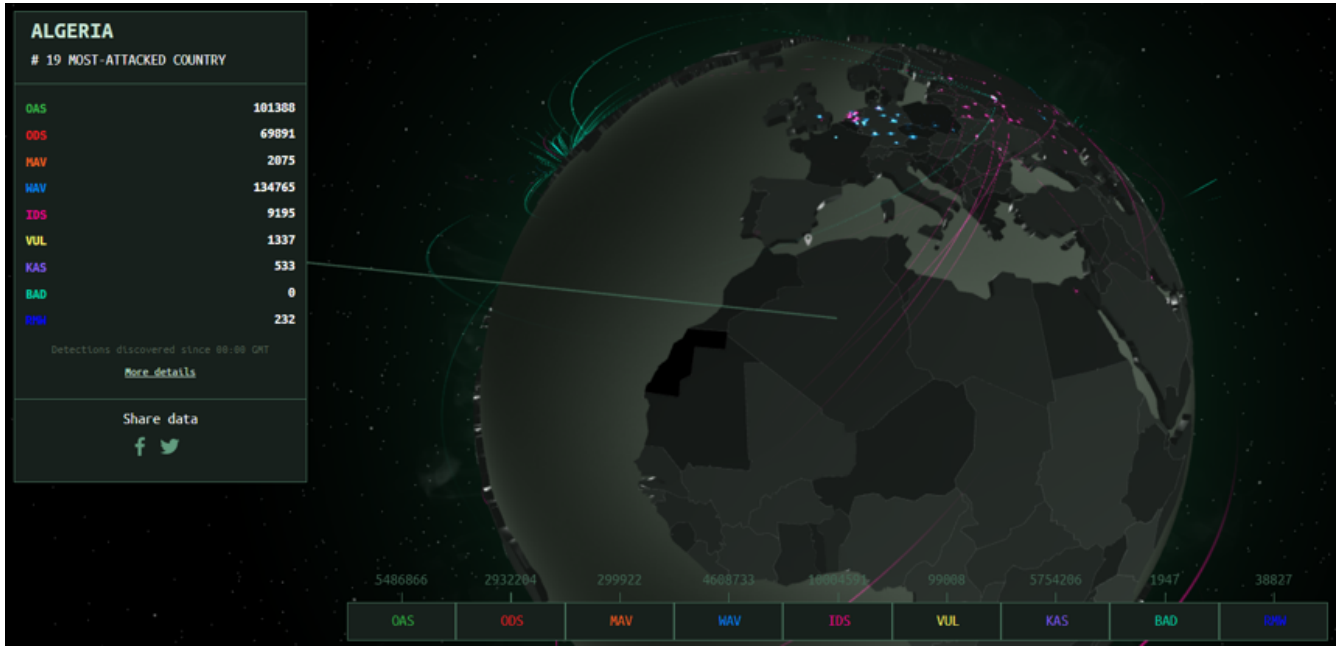
Position de l'Algérie :

- **7ème place mondiale**
- **28,64%** des utilisateurs attaqués

Source : securelist.fr

Surveillance en Temps Réel

Visualiser la cyberguerre



La sécurité informatique nécessite une veille permanente. Des outils comme la **Cybermap de Kaspersky** permettent de visualiser les flux d'attaques en direct.

- Ces cartes montrent l'intensité des attaques (OAS, ODS, WAV...).
- L'Algérie figure régulièrement dans le top 20 des pays les plus attaqués.

`https://cybermap.kaspersky.com/`

Une Politique de Sécurité Informatique

Définition

Une politique de sécurité informatique est un document de référence qui définit un plan d'actions pour maintenir un niveau de sécurité cible.

Une vision "Top-Down" : Elle ne se limite pas à la technique ; elle reflète la **vision stratégique de la direction** de l'organisme (PME, industrie, administration, État...).

Les 4 piliers d'une politique efficace :

1. **Règlementation :** Élaborer des règles, procédures et installer les outils techniques adéquats.
2. **Réaction :** Définir les actions et les contacts en cas de détection d'intrusion.
3. **Humain :** Sensibiliser les utilisateurs aux risques du Système d'Information (SI).
4. **Gouvernance :** Préciser clairement les rôles et responsabilités de chacun.

Pour illustrer la politique, voici des règles standards concernant l'authentification.

Bonnes pratiques mots de passe

- **Unicité :** Chaque utilisateur doit avoir un ID et un mot de passe uniques, conformes à la norme de complexité de l'entreprise.
- **Confidentialité absolue :** Interdiction formelle de partager son mot de passe, quel que soit le rang ou le titre du demandeur.
- **Stockage :** Les mots de passe ne doivent jamais être écrits sur papier ou stockés en clair (fichier texte lisible).

Procédure en cas d'incident

Si une attaque ou une compromission est suspectée :

1. Signaler immédiatement l'incident au service d'assistance (Helpdesk).
2. Procéder sans délai au changement du mot de passe.

L'Audit de Sécurité

L'audit de sécurité est une évaluation méthodique d'un Système d'Information (SI) à un instant **T**.

Missions principales :

- **Cartographier :** Identifier les points forts et surtout les vulnérabilités (points faibles).
- **Recommander :** Proposer des actions correctives pour supprimer les failles.
- **Analyser :** Souvent couplé à une analyse de risques.

Types d'audit :

- **Audit Interne :** Réalisé par l'équipe sécurité de l'entreprise.
- **Audit Externe :** Réalisé par un tiers de confiance (plus objectif).

Remarque

L'objectif ultime est de vérifier l'écart entre la politique de sécurité théorique et son application réelle sur le terrain.

Pratiques et Méthodologies d'Audit

Un audit complet combine plusieurs approches pour couvrir toutes les dimensions du SI.

Interviews Échanges avec le personnel (admins, utilisateurs) pour comprendre les processus humains.

Relevés de configuration Analyse profonde des paramètres des serveurs, routeurs et pare-feux.

Audit de code Lecture du code source pour déceler des failles logiques ou de programmation.

Fuzzing Injection de données aléatoires dans une application (boîte noire) pour tester sa robustesse aux erreurs.

Test d'intrusion Simulation d'attaques réelles (détaillé par la suite).

Définition

Un **Test d'Intrusion** (ou *Pentest*) consiste à analyser une cible en adoptant le point de vue et les méthodes d'un pirate informatique.

Périmètre de la cible :

- Une adresse IP spécifique ou un serveur web.
- Une application.
- Un réseau complet d'entreprise.

Distinction importante : C'est une photographie à l'instant T. Il ne faut pas le confondre avec le simple scan de vulnérabilités (voir slide suivant).

Le scan de vulnérabilité est souvent une sous-partie du test d'intrusion, mais il est moins complet.

Caractéristiques

- **Automatisé :** Utilisation d'outils logiciels pour scanner la cible.
- **Énumération :** Il liste les failles potentielles détectées.
- **Limites :** Il ne tente pas de *qualifier* la faille ni de vérifier si elle est réellement exploitable (pas de preuve de concept).

Quand et Comment réaliser un Pentest ?

La sécurité est un processus continu, le pentest doit s'inscrire dans le cycle de vie du projet.

Le Timing (Quand ?)

1. **Conception :** Pour anticiper les failles avant la mise en production (Security by Design).
2. **Exploitation :** À intervalles réguliers pour vérifier la robustesse dans le temps.
3. **Post-Incident :** Après une cyberattaque pour comprendre la brèche et éviter la récidive.

Le type (D'où ?) Il peut être réalisé depuis l'extérieur (Internet) ou depuis l'intérieur du réseau.

Les Vecteurs d'Attaque : Externe vs Interne

Test d'Intrusion Externe

- **Position :** L'attaquant est sur Internet.
- **Scénario :** Simule un pirate essayant de pénétrer la forteresse numérique depuis l'extérieur.
- **Cible :** Serveurs Web, VPN, pare-feux exposés.

Test d'Intrusion Interne

- **Position :** L'attaquant est déjà dans le réseau local.
- **Scénario :**
  - Employé malveillant (espionnage, vengeance).
  - Poste compromis (employé victime de phishing).

Les Conditions du Test (Niveaux de connaissance)

Black Box, Grey Box, White Box

On classe les tests selon le niveau d'information fourni au pentesteur avant le début de l'audit.

- **Boîte Noire (Black Box) :**
  - Aucune information préalable.
  - Simulation réaliste d'un pirate externe "aveugle".
- **Boîte Grise (Grey Box) :**
  - Information limitée (ex : un compte utilisateur standard).
  - Permet de tester l'élévation de privilèges ou les risques internes.
- **Boîte Blanche (White Box) :**
  - Transparence totale (accès au code source, architecture, comptes admin).
  - Audit le plus exhaustif et rapide.

Stratégie : Choisir le bon test

Il n'y a pas de "meilleur" test absolu, tout dépend des objectifs de l'organisation.

Remarque

Le choix impacte directement les résultats. Une stratégie mal définie peut donner un faux sentiment de sécurité.

Critères de décision :

1. **Quoi protéger ?** (Données clients, secrets industriels, disponibilité du service).
2. **Contre qui ?** (Script kiddies, concurrents, employés négligents).
3. **Quel budget/temps ?** (La boîte blanche est plus efficace mais demande plus de collaboration).

Il est crucial de définir le périmètre et le type d'attaque redouté avant de lancer l'audit.

Les Antivirus

Un antivirus est un logiciel conçu pour protéger le système contre les programmes malveillants.

Fonctions principales

Il doit être capable de **détecter** la présence de virus, de les **neutraliser** et, si possible, de les **éliminer**.

Les 3 méthodes de neutralisation :

1. **Désinfection :** Suppression uniquement du code malveillant injecté dans un fichier sain.
2. **Suppression :** Effacement complet du fichier infecté (si la désinfection est impossible).
3. **Mise en quarantaine :** Déplacement du fichier dans un espace sécurisé et isolé pour empêcher son exécution tout en le conservant pour analyse.

Cette méthode repose sur la comparaison des fichiers avec une base de données de "signatures" connues.

- **Principe :** Chaque virus possède une empreinte unique (signature). L'antivirus scanne les fichiers à la recherche de ces empreintes.
- **Condition critique :** L'efficacité dépend entièrement de la **mise à jour régulière** de la base virale.

Limites de la signature

- Ne détecte pas les virus nouveaux (inconnus de la base).
- Difficulté face aux **virus polymorphes** qui utilisent le camouflage (chiffrement, modification de code) pour changer de signature à chaque réplication.

Au lieu de chercher le virus, on surveille les modifications suspectes des fichiers sains.

- **Mécanisme :** L'antivirus crée une base de données de référence contenant les caractéristiques des exécutables sains (date, taille, somme de contrôle/hash).
- **Détection :** Si un exécutable change de caractéristiques (ex : sa taille augmente ou son hash change), l'antivirus alerte l'utilisateur.

Remarque

C'est une méthode efficace pour repérer une infection active, car un virus doit souvent modifier un programme hôte pour s'y insérer.

Principe

L'analyse heuristique ne cherche pas une signature précise, mais analyse le **comportement** d'un programme. Si une application agit comme un virus (ex : tente d'écrire dans le secteur de démarrage), elle est bloquée.

Avantages :

- Peut détecter des virus inconnus ("Zero-day") sans mise à jour préalable de la base.

Inconvénients :

- Risque élevé de **Faux Positifs** (alerter à tort sur un logiciel légitime).

Règle d'or

Un antivirus sans mise à jour est inutile. Mais la meilleure protection reste le comportement de l'utilisateur.

Les réflexes de sécurité :

- **Méfiance :** Ne pas ouvrir de pièces jointes ou liens suspects (email, réseaux sociaux).
- **Vérification :** Utiliser des outils comme *VirusTotal.com* pour scanner un fichier douteux avec plusieurs moteurs.
- **Sobriété numérique :** Éviter les téléchargements inutiles et désinstaller les applications non utilisées (réduction de la surface d'attaque).
- **Mises à jour :** Système d'exploitation (OS) et applications doivent être à jour.

Il existe une large gamme de solutions, adaptées à différents systèmes d'exploitation.

Solutions Libres (Open Source) :

- **ClamAV :** Référence sous Linux (licence GPL).
- **Chkrootkit :** Spécialisé dans la détection de rootkits sous Unix.
- **Moon Secure AV :** Basé sur ClamAV pour Windows.

Solutions Propriétaires :

- **Leaders du marché :** Bitdefender, Kaspersky, ESET (NOD32).
- **Autres acteurs :** Symantec (Norton), McAfee, Avast, Avira.

Pour une comparaison exhaustive : voir Liste des logiciels antivirus sur Wikipédia.

Source

Conclusion sur les Antivirus

- Les antivirus ne sont pas infaillibles (aucun logiciel ne l'est).
- Ils constituent néanmoins une barrière indispensable, une "ceinture de sécurité" numérique.
- Ils doivent être considérés comme une couche de protection, complémentaire à une politique de sécurité rigoureuse et à la vigilance humaine.

Conseil

Ne négligez jamais l'installation et la maintenance d'un antivirus, quel que soit votre système d'exploitation.

Les Pare-Feu (Firewalls)

Définition et Rôle du Firewall

Définition

Un **firewall** (ou pare-feu) est un système de protection servant à sécuriser un réseau informatique en filtrant les communications selon une politique de sécurité prédéfinie.

Principes de base :

- Il sépare un réseau de confiance (ex : réseau interne) d'un réseau non sûr (ex : Internet).
- Il examine chaque paquet de données entrant ou sortant.
- Il agit comme un filtre : il laisse passer les flux autorisés et bloque les flux interdits.

Types :

- **Types de filtrage** : Le filtrage simple de paquet (Stateless), le filtrage de paquet avec état (Stateful), le filtrage applicatif.
- **Types de firewalls** : Les firewalls matériels et les firewalls logiciels

Le Filtrage de Paquets Simple (Stateless)

Il opère aux couches 3 (Réseau) et 4 (Transport) du modèle OSI.

Fonctionnement : Le pare-feu analyse les en-têtes de chaque paquet individuellement, sans lien avec les paquets précédents.

Critères de filtrage :

- Adresses IP source et destination.
- Numéros de ports (ex : Port 80 pour HTTP, 443 pour HTTPS).
- Type de protocole (TCP, UDP, ICMP).
- Sens du trafic (Entrant/Sortant).

Avantage : Très rapide et peu coûteux en ressources.

Problème : Le pare-feu ne garde pas d'historique des connexions, il analyse chaque paquet indépendamment. Il ne peut pas différencier un paquet légitime d'un paquet usurpé (spoofing).

L'Inspection de Paquets avec État (Stateful)

Contrairement au filtrage simple, le pare-feu **Stateful** garde une trace des connexions en cours dans une **table d'état**.

Points clés :

- Il vérifie si un paquet entrant correspond à une demande sortante légitime effectuée précédemment.
- Il valide la séquence du protocole (ex : le "Handshake" TCP).

Exemple : Si vous demandez une page web, le pare-feu enregistre que votre machine attend une réponse du serveur distant sur un port spécifique. Dès que la réponse arrive, il la laisse passer car elle est "attendue".

Problème : Même s'il est stateful, ce type de pare-feu n'analyse pas le contenu applicatif (HTTP, FTP, DNS, etc.), il ne détecte pas les attaques applicatives (SQL injection, XSS...)

Le Pare-feu Applicatif (Gateway / Proxy)

Il travaille à la couche 7 (Application) du modèle OSI.

Mécanisme :

- Le client ne parle jamais directement au serveur.
- Le Proxy reçoit la requête, l'**analyse en profondeur** (cherche des virus, des commandes interdites ou des mots-clés).
- Si la requête est saine, le Proxy la reformule et l'envoie au serveur.

Avantage : Sécurité maximale, car il comprend le contenu (ex : filtrer une URL spécifique dans une connexion HTTP).

Inconvénient : Plus lent car il doit traiter tout le contenu des données.

Comparaison des Technologies

Type	Couche OSI	Vitesse	Sécurité
Paquet (Simple)	3 / 4	Très Rapide	Faible
Stateful	3 / 4	Rapide	Bonne
Applicatif	7	Lent	Excellente

Remarque importante : Aujourd'hui, la plupart des pare-feux modernes (NGFW - Next Generation Firewalls) combinent ces trois méthodes pour offrir une défense en profondeur.

Le Firewall Matériel (Hardware Firewall)

Le firewall matériel est un appareil dédié (appliance) qui s'interpose entre le réseau local et le réseau extérieur.

Caractéristiques principales :

- Intégré directement dans une machine spécifique faisant office de « boîte noire ».
- Offre une intégration parfaite entre le logiciel de filtrage et le matériel.
- Souvent utilisé dans les environnements haut de gamme pour éviter toute modification logicielle non autorisée.

Avantages :

- Administration simplifiée.
- Haut niveau de sécurité.
- Ne ralentit pas les serveurs.

Inconvénients :

- Coût souvent élevé.
- Dépendance vis-à-vis du constructeur pour les mises à jour.

Exemples de Pare-feux Matériels

- **SonicWall TZ400 :** Très utilisé dans les PME pour sa polyvalence.



- **Zyxel ZyWALL 110 :** Reconnu pour sa gestion efficace des tunnels VPN et sa protection multicouche.



Le Firewall Logiciel : Solutions Personnelles

Contrairement au matériel dédié, le pare-feu logiciel s'exécute comme une application sur un système d'exploitation hôte.

Pare-feux personnels :

- Destinés aux particuliers et aux postes de travail individuels.
- Installés directement sur l'ordinateur à protéger.

Points de vigilance :

- **Risque :** Si un attaquant prend le contrôle du système, il peut désactiver le logiciel.
- **Performance :** Utilise les ressources (CPU/RAM) de l'ordinateur, ce qui peut le ralentir légèrement.
- **Exemples :** GlassWire, ZoneAlarm, Comodo.

Le Firewall Logiciel : Solutions Avancées (Linux)

Pour une sécurité réseau plus élevée et un contrôle granulaire, on utilise souvent des systèmes basés sur Linux.

Pourquoi Linux ?

- Offre une sécurité réseau nativement plus robuste.
- Permet une personnalisation totale des règles.

Outils de référence :

- **iptables :** L'outil le plus courant, il utilise directement le noyau (kernel) Linux pour filtrer les paquets.
- **Avantage :** Niveau de sécurité très élevé et coût logiciel nul (Open Source).
- **Inconvénient :** Nécessite une expertise solide en administration système.

Certifications en Cybersécurité : Un Standard Mondial

Les certifications sont essentielles pour valider les compétences et suivre l'évolution rapide des menaces.

Niveau Fondamental :

- **CompTIA Security+ :** Idéale pour débuter, elle couvre les bases (cryptographie, gestion des menaces).
- **Certified Ethical Hacker (CEH) :** Focalisée sur les tests d'intrusion et les techniques des attaquants.

Niveau Avancé / Management :

- **CISSP :** La certification la plus prestigieuse pour les postes de direction et de gestion des risques.
- **CISM :** Spécialisée dans la gouvernance de la sécurité et la conformité.

Les Métiers de la Sécurité Informatique

Le domaine offre une grande diversité de rôles selon les affinités (technique ou gestion).

- **Administrateur de sécurité réseau :** Met en œuvre les stratégies de protection et résout les problèmes d'accès.
- **Analyste des risques :** Étudie les menaces potentielles pour protéger les actifs de l'entreprise.
- **Pentester (Hacker Éthique) :** Teste la résistance des systèmes en tentant de s'y introduire légalement.
- **Spécialistes dédiés :** Experts en IDS (systèmes de détection d'intrusion), pare-feu ou VPN.

Conclusion : Vers une Vigilance Constante

La sécurité informatique n'est pas un état stable, mais un processus continu.

Points clés à retenir

- Le cyberespace est un monde à hauts risques.
- Il est impératif d'identifier les risques pour adapter les protections.
- Même avec les meilleurs outils (Firewalls, Antivirus), l'**attitude humaine** reste la première ligne de défense.

Bibliographie

- **Cybersécurité et Confidentialité**
  - *Security and Privacy in Web 3.0*, Shen, M. et al., Springer, 2024.
  - *Cybersécurité : analyser les risques, mettre en œuvre les solutions*, S. Ghernaouti, DUNOD, 2019.
- **Bases et Fondements de la Sécurité**
  - *Tout sur la sécurité informatique*, J-F. Pillou et J-P. Bay, DUNOD, 2013.
  - *Sécurité informatique et Réseaux*, S. Ghernaouti, DUNOD, 2013.
- **Gestion et Surveillance**
  - *Tableaux de bord de la sécurité réseau*, C. Llorens, L. Levier et D. Valois, Eyrolles, 2011.
- **Méthodologie et Principes**
  - *Sécurité informatique - Principes et méthodes*, L. Bloch et C. Wolfhugel, Eyrolles, 2009.
- **Ressources en ligne**
  - Site : Wikipédia – Portail de la Sécurité des Systèmes d'Information.